

Contents

1 The Evolution of Penetration Testing, Red Teaming, and Bug Bounties

Into the Abyss

The Uncharted Territory

The AI Crash Course

Into the Breach

Culmination

Next Steps

Industry Overview

What Are Penetration Testing, Red Teaming, and Bug Bounties?

Why Are These Disciplines Important?

How Have They Evolved Over Time?

The Early Days and Evolution of Penetration Testing

The Rise of Red Teaming

The Emergence of Bug Bounty Programs

The Convergence of Penetration Testing, Red Teaming, and Bug Bounties

The Future of Penetration Testing, Red Teaming, and Bug Bounties

The Increasing Use of AI and ML in Penetration Testing, Red Teaming, and Bug Bounties

Test Your Skills

2 Introduction to Red Teaming

What Is Red Teaming?

The Importance of Red Teaming

Identifying Critical Vulnerabilities

Challenging Assumptions

Emulating Industry-Specific Threats

Red Team Frameworks and Methodologies

MITRE ATT&CK Framework

Unified Kill Chain

TIBER-EU

CBEST

Red Team Engagements

Full-Scope

Objective-Based

Adversary Emulation (Scenario-Based)

Purple Team

Tabletop

Red Team Challenges

Leveling Up Other Teams

Lack of Findings

References

Test Your Skills

3 Red Team Infrastructure

An Overview of Red Team Infrastructure

Command and Control

C2 Communication Channels

Redirectors

Command and Control Setup

Test Your Skills

4 Modern Red Team Methodology and Tools

Planning

Rules of Engagement

Kickoff Call

Communication

Reconnaissance

Autonomous System Number (ASN)

Certificate Transparency

Proxying Traffic

Domain Name Service

Metadata

Username Collection

Software Discovery

Leaked Data

Initial Access

Password Spraying

Mobile Device Management (MDM)

Social Engineering and Physical Access

Payload Preparation

Web Application Vulnerabilities

Persistence

Lateral Movement

Obtaining Credentials

Gathering Domain Information

Kerberoasting

Active Directory Certificate Services

SCCM Abuse

Post-Exploitation

Reporting

Test Your Skills

5 Social Engineering and Physical Assessments

Phone Pretexting: Let's Dial into Your Target

Reconnaissance

Preparing Pretext

Execution

Spear Phishing: Time to Reel In Your Target

Infrastructure

Formulating Your Email or Instant Message

Execution

Can You Hear Us from the Inside?

Remote Reconnaissance

Badge Cloning

Onsite Reconnaissance

Social Engineering in Person

Physical Building Bypasses

Test Your Skills

6 Advanced Post-Exploitation Techniques

An Overview of Post-Exploitation

Evaluating Detection and Response Capabilities and

Understanding the Impact of a Breach

Improving Blue Team Capabilities

How to Maintain Access, Use Persistence Mechanisms, and
Create Backdoors

Types of Backdoors

Reverse Shells vs. Bind Shells

Patching Binaries to Include a Backdoor

Avoiding Detection Using Code Obfuscation

System-Level Backdoors

Kernel-Level Backdoors

Hardware and Firmware Backdoors

Scheduled Jobs and Tasks

New Users

Command and Control (C2) and Covert Channels

How DNS Tunneling Works

HTTP/HTTPS Tunneling

Nontraditional Protocols

Additional C2 Techniques and Tools

How to Perform Lateral Movement

Post-Exploitation Scanning

Legitimate Utilities and Living Off the Land

PowerShell for Post-Exploitation Tasks

PowerSploit and Empire

BloodHound

Windows Management Instrumentation for Post-
Exploitation Tasks

Sysinternals and PsExec

Windows Remote Management (WinRM) for Post-
Exploitation Tasks

Living-Off-the-Land Bins, Libraries, and Useful Scripts

Post-Exploitation Privilege Escalation

How to Cover Your Tracks

Steganography

Test Your Skills

7 Active Directory and Linux Environments

Active Directory Fundamentals

Centralized Data Repository and High Availability

Security

Active Directory Architecture

AD Trust Relationships

Key Active Directory Protocols and Services

Microsoft Entra ID and Azure

Active Directory Attack Techniques

How to Set Up the Lab

AD Recon and Enumeration

Password Spray and ASREPROast

Useful LDAP Queries for Windows Active Directory

Assessments

BloodHound Is Awesome

Using Responder for Credential Harvesting in Active

Directory Environments

Using Secretsdump to Extract Credentials

Using Lsassy to Extract Credentials from LSASS

Using DonPAPI to Target the Windows Data Protection

Application Programming Interface (DPAPI)

ADCS Reconnaissance and Enumeration with Certipy

and BloodHound

Exploitation Using Certipy

Abusing Discretionary Access Control Lists (DACLS) and

Access Control Entries (ACEs)

The Golden SAML Attack

Microsoft Entra Connect (Azure AD Connect) Sync

Account Takeover

Microsoft Entra Privileged Identity Management (PIM)

Abuse

Advanced Linux Environment Attack Techniques

A Quick Refresher on How Buffer Overflows Work

How to Exploit Buffer Overflows

Examples of Vulnerable Code

Bypassing No-Execute (NX) Stack with Return-Oriented

Programming (ROP)

Bypassing NX with ROP

Test Your Skills

Project 7-1

8 The Future of Red Teaming Beyond the AI Revolution

Understanding the Current State of AI in Red Teaming

Creating AI-Powered Offensive Security Tools

LangChain, Prompt Templates, LangSmith, LangGraph,
and LlamaIndex

Examining Fine-Tuned Uncensored AI Models

Understanding Retrieval-Augmented Generation (RAG) for
Red Teaming

Vector Embeddings

Vector Database Storage

User Query Processing

Semantic Search and Document Retrieval

Context Preparation for LLMs or SLMs

Response Generation and Post-Processing and
Refinement

Red Teaming AI and Autonomous Systems

Keeping Pace with Rapidly Evolving Technologies

Test Your Skills

9 Introduction to Bug Bounty and Effective Reconnaissance

Understanding Bug Bounty Programs

Types of Bug Bounty Programs

Attack Surface Management vs. Bug Bounties

Vulnerability Disclosure Programs (VDPs) vs. Bug
Bounties

Getting Started: Preparing Yourself as an Ethical
Hacker in Bug Bounty Programs

Understanding the Scope and Rules of Engagement

Exploring Effective Reconnaissance

Active vs. Passive Reconnaissance

Understanding OSINT

Leveraging DNS for Recon

Identifying Technical and Administrative Contacts

Identifying Cloud vs. Self-Hosted Assets

[Social Media Scraping](#)

[Cryptographic Flaws](#)

[Obtaining Sensitive Information About External and Internal Hosts Using Certificate Transparency](#)

[Leveraging Password Dumps](#)

[Recon from File Metadata](#)

[Strategic Search Engine Analysis/Enumeration](#)

[Website Archive/Caching](#)

[Public Source-Code Repositories, Secrets, and Other Sensitive Information](#)

[Performing Reconnaissance with Recon-ng](#)

[Shodan](#)

[Amass, Maltego, and Other OSINT Tools](#)

[Using Generative AI and the Gorilla Large Language](#)

[Model to Interact with Tools Like Amass](#)

[Using Open-Interpreter to Interact with Recon Tools](#)

[Performing Active Reconnaissance](#)

[Creating Your Own Scanner Using Python](#)

[Exploring the Different Types of Enumeration](#)

[Using BloodHound for a Bug Bounty](#)

[Packet Inspection and Eavesdropping](#)

[Understanding the Art of Performing Vulnerability Scans](#)

[Understanding the Types of Vulnerability Scans](#)

[Challenges to Consider When Running a Vulnerability Scan](#)

[Performing Web Application and API Recon](#)

[Directory and File Brute-Forcing](#)

[API Recon](#)

[Communicating Your Findings and Creating Effective Bug Bounty Reports](#)

[Test Your Skills](#)

[Exercises](#)

[10 Hacking Modern Web Applications and APIs](#)

[Overview of Web Application-Based Attacks, the OWASP Top 10 for Web Applications, and OWASP Top 10 for LLM Applications](#)

[The HTTP Protocol](#)

[Understanding Web Sessions](#)

[OWASP Top 10 for Web Applications](#)

[OWASP Top 10 for LLM Applications](#)

[Building Your Own Web Application Lab](#)

[Understanding Business Logic Flaws](#)

[Understanding Injection-Based Vulnerabilities](#)

[Hacking Databases and Exploiting SQL Injection](#)

[Vulnerabilities](#)

[Command Injection Vulnerabilities](#)

[Lightweight Directory Access Protocol \(LDAP\) Injection](#)

[Vulnerabilities](#)

[Exploiting Authentication-Based Vulnerabilities](#)

[Brute-Forcing Credentials](#)

[Understanding Session Hijacking](#)

[Understanding Redirect Attacks](#)

[Taking Advantage of Default Credentials](#)

[Exploiting Kerberos Vulnerabilities](#)

[Exploiting Authorization-Based Vulnerabilities](#)

[Understanding Parameter Pollution](#)

[Exploiting Insecure Direct Object Reference \(IDOR\)](#)

[Vulnerabilities](#)

[Understanding Cross-Site Scripting \(XSS\) Vulnerabilities](#)

[Reflected XSS Attacks](#)

[Stored XSS Attacks](#)

[XSS Evasion Techniques](#)

[XSS Mitigations](#)

[Understanding Cross-Site Request Forgery and Server-Side](#)

[Request Forgery Attacks](#)

[Server-Side Request Forgery Attacks](#)

[Exploiting an SSRF Vulnerability Using WebSploit Labs](#)

[Understanding Clickjacking](#)

[Exploiting Security Misconfigurations](#)

[Exploiting Directory Traversal Vulnerabilities](#)

[Understanding Cookie Manipulation Attacks](#)

[Exploiting File Inclusion Vulnerabilities](#)

[Local File Inclusion Vulnerabilities](#)

[Remote File Inclusion Vulnerabilities](#)

[Exploiting Insecure Code Practices](#)

[Comments in Source Code](#)

[Lack of Error Handling and Overly Verbose Error Handling](#)

[Hard-Coded Credentials](#)

[Race Conditions](#)

[Unprotected APIs](#)

[Hidden Elements](#)

[Lack of Code Signing](#)

[Using Additional Web Application Hacking Tools](#)

[Test Your Skills](#)

[11 Automating a Bug Hunt and Leveraging the Power of AI](#)

[Traditional Bug Hunting Methods](#)

[Limitations of Manual Bug Hunting](#)

[AI-Powered Automation in Bug Hunting](#)

[AI Capabilities of Bug Bounty Platforms](#)

[A Comprehensive View of an Organization's External Risk Exposure](#)

[Vulnerability Prioritization Using AI](#)

[AI-Created Scanner Templates](#)

[AI Model Training, Fine-Tuning, and RAG for Bug Bounties](#)

[Deploying AI Models](#)

[Fine-Tuning AI Models](#)

[Using RAG and AI Agents for Bug Bounty Hunting Tool Calling](#)

[Challenges of Using AI for Bug Bounty Hunting](#)

[Censored Models and Guardrails](#)

[Hallucinations or Confabulations](#)

[Test Your Skills](#)

[Answers to Multiple-Choice Questions](#)

[Index](#)

Register your copy of *Redefining Hacking: A Comprehensive Guide to Red Teaming and Bug Bounty Hunting in an AI-Driven World* at

[**informit.com**](http://informit.com) for convenient access to downloads, updates, and corrections as they become available. To start the registration process, go to informit.com/register and log in or create an account. Enter the product ISBN (**9780138363611**) and click Submit. Once the process is complete, you will find any available bonus content under “Registered Products.”